

Actividad 04

Responder:

Parte A: Identificación de riesgos

1. ¿Qué información del colegio considera “activos sensibles”? ¿Por qué?

La información de pagos de colegiaturas de todos los padres, los reportes psicopedagógicos de cada estudiante, las credenciales o datos personales tanto de docentes como de estudiantes y lo propios correos internos del colegio

En el caso de estos datos se puede decir que son "activos sensibles" porque al dejar de ser privados y pasen a ser expuestos, pueden ser utilizados para causar algún tipo de daño a los propietarios de esos datos

2. ¿Qué vulnerabilidades detecta en las situaciones descritas?

Utilización de medios físicos no confiables y sin protección

Falta de control de las sesiones abiertas

Información sensible no cifrada ni protegida

Falta de capacitación al personal de cómo utilizar el sistema

Falta de políticas para cuentas que ya no deberían estar habilitadas

El acceso sin restricciones a carpetas con datos sensibles

3. ¿Qué amenazas se hicieron realidad? ¿Se podrían haber evitado?

Ser perdió la USB, esto se hubiera podido evitar si la USB contara con algún tipo de seguridad como pedir contraseña para poder acceder los datos y otro punto importante es que lo mejor es siempre contar con respaldo de los datos.

Por dejar las sesiones abiertas se da la suplantación de identidad, se podría haber evitado informando a los usuarios y de los riesgos que se corren o para no dar lugar a errores humanos se podría implementar una política de cierre automático de sesión

Se filtra la información de pago, lo importante aquí es contar con un control de acceso a esta información

Logran modificar las notas, para evitar esto se puede fortalecer de mejor manera la gestión de cuentas, como por ejemplo si ya tiene un cierto tiempo de inactividad o si el estudiante ya no se encuentra activo, entonces desactivar su cuenta.

Parte B: Aplicación de ISO 27001

4. ¿Cómo podría el colegio aplicar un SGSI para prevenir cada uno de los incidentes?

Lo primero sería realizar un inventario de todo con lo que se cuenta, ya teniendo claro que es lo que se tiene entonces se pasa a un análisis y clasificación de riesgo, esto para poner atención primeramente a lo más importante y evitar que pase algo similar o peor a lo que

se mencionó. Ya aquí se va a partes específicas también aprendiendo de los errores, entonces se puede implementar ahora controles de accesos, eliminación y inhabilitación de cuentas de estudiantes inactivos, cifrado y hacer respaldo de los datos y para tratar de evitar los errores humanos sería bueno capacitar al personal para que conozca adecuadamente su sistema y aprenda a usarlo como también ellos sepan de los riesgos que se corren con la manera actual de trabajar

5. Proponga un control por cada pilar (personas, procesos, tecnología) que podría implementarse en este colegio.
 - Personas, realizar capacitaciones sobre ciberseguridad donde se den a conocer amenazas y riesgos, cómo puede actuar el personal para evitar que el colegio vuelva a ser vulnerado
 - Procesos, implementar políticas de control de accesos, cierres de sesión y inhabilitación de cuentas de estudiantes y de docentes o en general de usuarios que ya se encuentren inactivos
 - Tecnología, contemplar una migración o por lo menos contar con un respaldo de la información en la nube y que esta tenga todas sus medidas de seguridad también

Parte C: Ética y cultura de seguridad

6. ¿Qué responsabilidad tienen los docentes y administrativos en el uso seguro de la tecnología?
Lo más importante es que tiene la responsabilidad de proteger los datos de los estudiantes como de sus encargados, es decir, como cuentan con la información de los pagos, claramente también tienen que cumplir con tener confidencialidad en el manejo de los datos. De igual manera considero que también se tiene la responsabilidad que tiene que reportar cualquier problema o inconveniente que pueda llegar a pasar
7. ¿Cómo influye la cultura institucional en que estos incidentes se repitan o se prevengan?
Si no se tiene una cultura comprometida con cumplir con sus responsabilidades pues es muy probable que estos problemas sigan pasando. Por otro lado una cultura institucional que considera la seguridad tiene que tratar la manera de reducir el error humano y por lo tanto tiene que tener un personal comprometido y que esté dispuesto a realizar un cambio y a capacitarse

Parte D: Propuesta de mejora

8. Imagine que usted es parte del equipo de seguridad del colegio. Diseñe una pequeña campaña de concienciación que se pueda implementar con alumnos y docentes.
 - Crear una especie de talleres para capacitar a los docentes sobre usar la tecnología de forma segura
 - Se puede fomentar una cultura de concientización para los estudiantes, es decir, que ellos elaboren carteles sobre la ciberseguridad así se promueve que ellos investiguen y

conozcan el tema

- En los talleres se pueden crear simulaciones de ataques o incidentes de ciberseguridad y de esa forma crear conciencia del riesgo real que se corre al seguir actuando de forma desinformada